

Layer 1 · Application code — WEAKEST

Every query adds the filter by hand
where: { organisation_id: ctx.orgId }

Forgettable in every new query.
eng-labs today: 1,330 occurrences
across 154 files

harder to bypass

Layer 2 · ORM middleware / repository

Scope injected once, centrally
BaseRepository.injectOrgScope()
or a Prisma client extension

Forgettable only by bypassing the
repository — catchable with lint.
eng-labs: 8 service classes adopted

harder to bypass

Layer 3 · Database — Row-Level Security

Postgres RLS policy on every table
SET app.tenant_id per connection

Cannot be forgotten in SQL at all.
The database refuses to return
another tenant's rows.

harder to bypass

Layer 4 · Separate database / instance — STRONGEST

Tenant resolved to its own connection
or its own deployment

A cross-tenant query is not
expressible. Isolation is physical.